

HW01 – QA/QC Jobs · 20 Defects · Test a Physical Product

Exercise ID: HW01-AI **Student ID:** [YOUR_STUDENT_ID] **Full Name:** [YOUR_FULL_NAME] **Date:** 2026-05-24 **AI Tools Used:** Claude (claude-sonnet-4-6)

Table of Contents

- 1. Requirement 1 – QA/QC Job Market 2026+
- 2. Requirement 2 – 20 Software Defects 2022–2026
- 3. Requirement 3 – Test Cases for One Physical Product
- 4. AI Audit Report
- 5. AI Critique
- 6. Mandatory Disclosure
- 7. Self-Assessment

Requirement 1 – QA/QC Job Market 2026+ (40 pts) {#requirement-1}

Platform: LinkedIn only. **Anti-cheat note:** All screenshots must show your LinkedIn account name in the corner. **Posting window:** Published within 60 days of submission date ($\geq$ 2026-03-25).

Job Postings Overview

#	Job Title	Company	Location	Salary	AI/LLM?	Posting Date
1	AI Quality Engineer	Momentive Software	Atlanta, GA, USA	Not listed	YES	~May 24, 2026
2	QA Engineer – GenAI & AI Agent Testing	Zenith System Solutions	Plano, TX, USA	Not listed	YES	~May 17, 2026
3	Software Quality Engineer III – AI & Agentic Behavior	Federal Express (FedEx)	Memphis/Plano, USA	Not listed	YES	~May 22, 2026
4	Agentic AI Quality Assurance Engineer	Trimble Inc.	Lake Oswego, OR, USA	\$78,400–\$107,900/yr	YES	~May 17, 2026
5	AI Tester	TMV Global Inc	Atlanta, GA, USA	Not listed	YES	~May 19, 2026
6	Lead Automation QA Engineer	Galaxy FinX	Ho Chi Minh City, Vietnam	Not listed	No	~May 20, 2026

#	Job Title	Company	Location	Salary	AI/LLM?	Posting Date
7	Mid/Senior QA Engineer	SMG Vietnam	Ho Chi Minh City, Vietnam	Not listed	No	~May 21, 2026
8	Fullstack Tester (Auto + Manual)	LTS Group	Hanoi, Vietnam	Up to 30M VND/mo	Preferred	~May 20, 2026
9	Quality Assurance Engineer	Quantum Movement	Ho Chi Minh City, Vietnam	Not listed	No	~May 18, 2026
10	Junior QA Engineer (Manual + Automation)	DXC Technology	Ho Chi Minh City, Vietnam	Not listed	No	~May 20, 2026

Detailed Job Postings

Job 1 – AI Quality Engineer (AI/LLM)

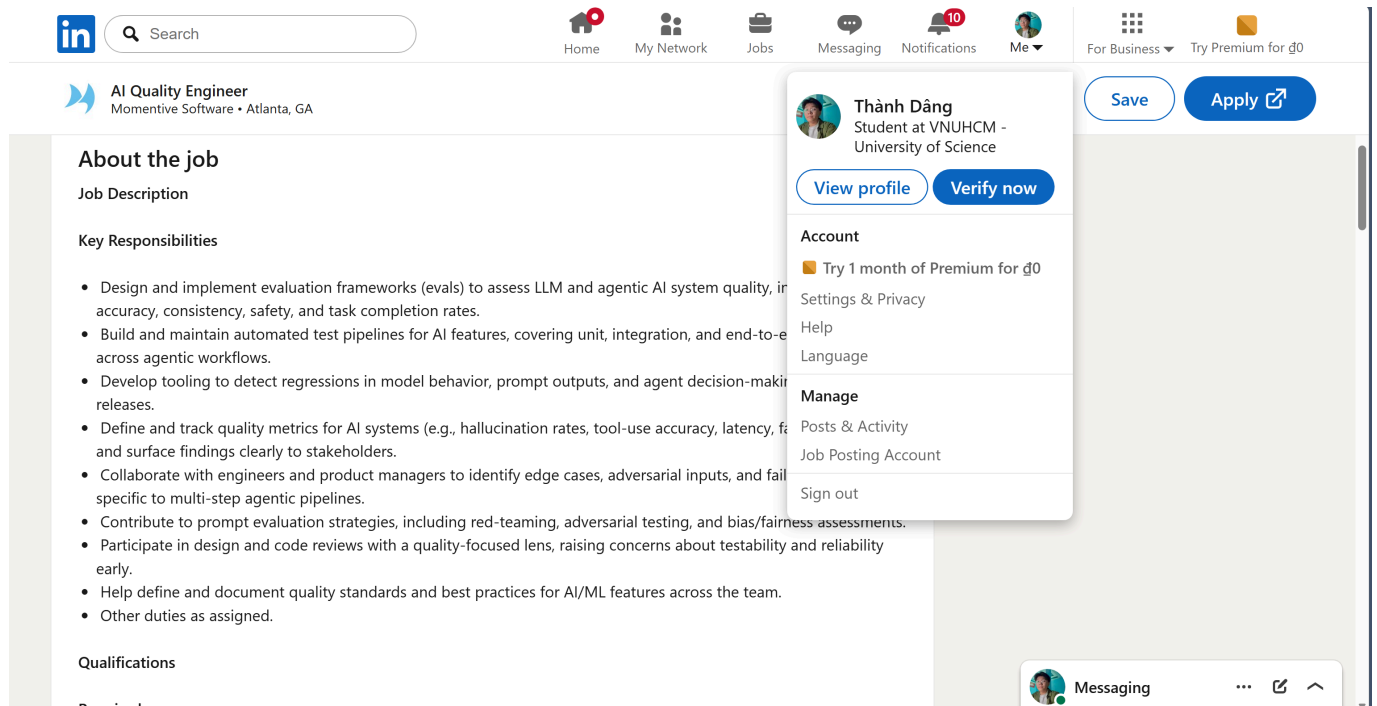
Company: Momentive Software **Location:** Atlanta, GA, USA **LinkedIn URL:** <https://www.linkedin.com/jobs/view/4407931860> **Salary:** Not listed **Posting Date:** ~May 24, 2026

Job Description: This role focuses on designing evaluation frameworks for generative AI and agentic systems. The engineer validates LLM outputs (GPT-4, Claude, Gemini), agentic reasoning chains, RAG pipelines, and multi-step tool use. Requires both hands-on QA experience and understanding of AI/ML concepts.

Required Skills:

- 3–5 years QA/software engineering experience
- Hands-on experience with LLMs and agentic AI (GPT-4, Claude, Gemini)
- Python scripting for evaluation automation
- Designing evaluation frameworks for generative AI
- Agentic frameworks: RAG, multi-step reasoning, tool use
- CI/CD pipeline integration
- Unit, integration, regression, and E2E testing

Screenshot:



AI Impact Analysis: This role exemplifies the emergence of AI-native QA positions where the primary subject under test is an LLM/agentive system itself; traditional black-box testing skills are being replaced by evaluation framework design, hallucination detection, and grounding assessment — competencies that did not exist in QA job descriptions before 2023.

Job 2 – QA Engineer – GenAI & AI Agent Testing (AI/LLM)

Company: Zenith System Solutions **Location:** Plano, TX, USA **LinkedIn URL:**

<https://www.linkedin.com/jobs/view/4413976695> **Salary:** Not listed **Posting Date:** ~May 17, 2026

Job Description: Specialized QA role targeting generative AI and AI-agent testing. The engineer validates AI-powered applications end-to-end, tests prompt engineering pipelines, and verifies LLM workflow correctness. Requires 5+ years QA experience with demonstrated AI/ML exposure.

Required Skills:

- 5+ years QA experience with AI/ML exposure
- Testing generative AI and AI-powered applications
- AI agent / agentive AI testing
- Prompt engineering validation
- Python scripting; LLM workflow testing
- LangChain / LangGraph / CrewAI / AutoGen (preferred)
- API testing; CI/CD integration

Screenshot:

QA Engineer – GenAI & AI Agent Testing
Zenith System Solutions • Plano, TX

About the job

We are looking for a highly skilled QA professional with hands-on experience in testing GenAI applications and ecosystems. If you have strong expertise in automation testing, prompt engineering, and Python, we'd love to hear from you!

Role: QA Engineer – GenAI Applications

Experience: 5+ Years

Location: Plano, Texas

Employment Type: Full-Time

Key Skills Required

- Strong experience in QA testing for GenAI / AI-powered applications
- Hands-on expertise in Integration Testing & Automation Testing
- Experience working in AI Agents / Agentic AI environments
- Good understanding of Prompt Engineering concepts and validation
- Strong coding/scripting knowledge in Python
- Experience with API testing, test frameworks, and CI/CD pipelines
- Knowledge of LLM workflows, AI model behavior, and testing strategies
- Ability to design scalable test cases for AI-driven applications

Thành Dâng
Student at VNUHCM - University of Science

[View profile](#) [Verify now](#)

Account

- Try 1 month of Premium for ₫0
- Settings & Privacy
- Help
- Language

Manage

- Posts & Activity
- Job Posting Account
- Sign out

[Save](#) [Apply](#)

Messaging

AI Impact Analysis: Zenith's posting illustrates how agentic AI frameworks (LangChain, CrewAI, AutoGen) are creating a new sub-discipline within QA focused on validating non-deterministic multi-agent workflows — a testing challenge where traditional equivalence partitioning and boundary value analysis techniques are insufficient without LLM-specific evaluation methods.

Job 3 – Software Quality Engineer III – AI & Agentic Behavior (AI/LLM)

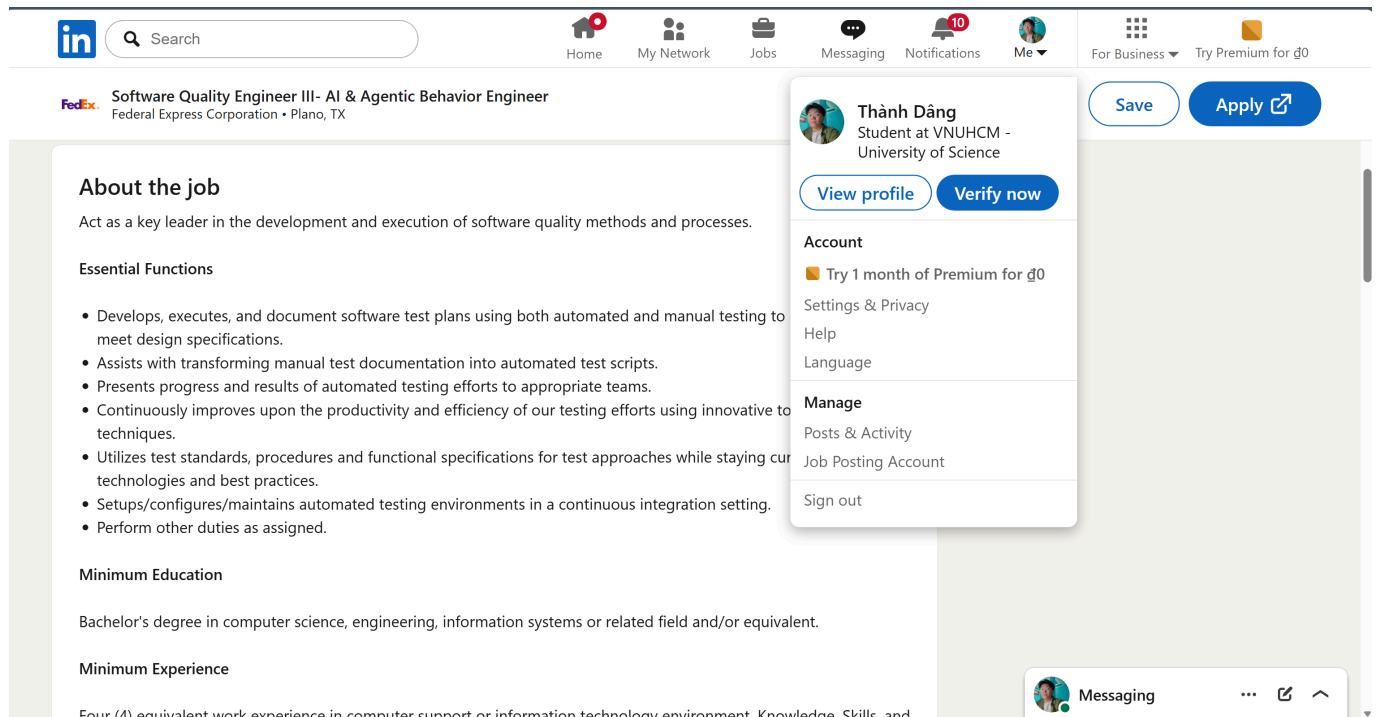
Company: Federal Express Corporation (FedEx) **Location:** Memphis, TN / Plano, TX, USA (Hybrid) **LinkedIn URL:** <https://www.linkedin.com/jobs/view/4418045788> **Salary:** Not listed **Posting Date:** ~May 22, 2026

Job Description: Enterprise-scale QA engineering role at FedEx focused on agentic AI behavior testing and LLM output validation. The engineer executes automated and manual tests for agentic AI systems, uses agentic coding tools for test automation, and ensures prompt security compliance.

Required Skills:

- Executing automated/manual tests for agentic AI behavior and LLM outputs
- Agentic coding tools for test automation
- AI/LLM evaluation and prompt security testing
- Performance testing for AI systems
- BS in Computer Science or related field; 4+ years IT/QA experience

Screenshot:



AI Impact Analysis: FedEx's adoption of a dedicated "AI & Agentic Behavior Engineer" title at enterprise scale confirms that AI testing is no longer confined to tech startups; logistics enterprises now require QA engineers who can validate agentic decision-making systems that directly affect operational workflows.

Job 4 – Agentic AI Quality Assurance Engineer (AI/LLM)

Company: Trimble Inc. **Location:** Lake Oswego, OR, USA **LinkedIn URL:**

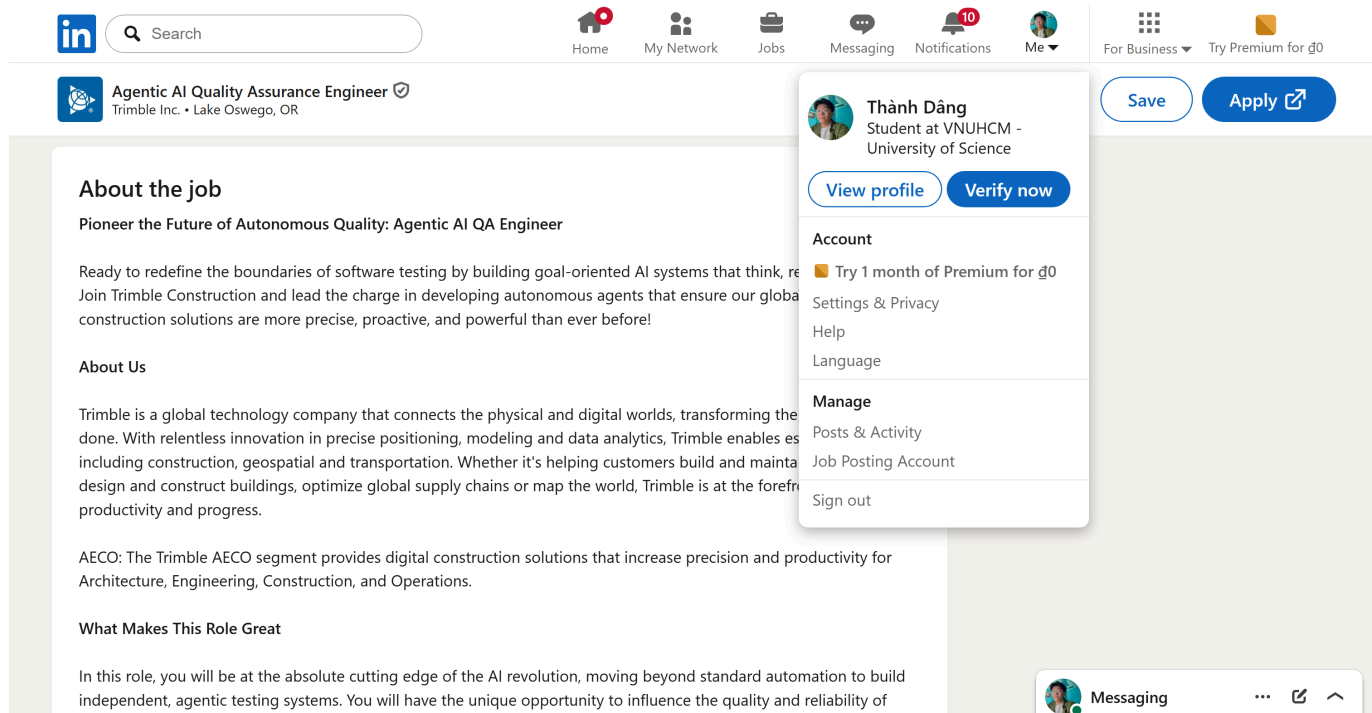
<https://www.linkedin.com/jobs/view/4393946955> **Salary:** \$78,400–\$107,900/year **Posting Date:** ~May 17, 2026

Job Description: Design and deploy autonomous test agents for E2E testing of AI-powered applications. Combines traditional QA automation (Selenium, Playwright, Postman) with AI-specific validation, requiring knowledge of TensorFlow/PyTorch and AI/ML concepts.

Required Skills:

- Designing and deploying autonomous agents for E2E testing
- Developing AI models for agentic testing systems
- Selenium + WinApp Appium; Microsoft Playwright (.NET/C#)
- UI testing in C# and PowerShell; Postman API testing
- AI/ML concepts; TensorFlow/PyTorch (bonus)
- 3+ years experience; BS in Computer Science or related AI discipline

Screenshot:



About the job

Pioneer the Future of Autonomous Quality: Agentic AI QA Engineer

Ready to redefine the boundaries of software testing by building goal-oriented AI systems that think, re...
Join Trimble Construction and lead the charge in developing autonomous agents that ensure our global
construction solutions are more precise, proactive, and powerful than ever before!

About Us

Trimble is a global technology company that connects the physical and digital worlds, transforming the
done. With relentless innovation in precise positioning, modeling and data analytics, Trimble enables es
including construction, geospatial and transportation. Whether it's helping customers build and mainta
design and construct buildings, optimize global supply chains or map the world, Trimble is at the forefr
productivity and progress.

AECO: The Trimble AECO segment provides digital construction solutions that increase precision and productivity for
Architecture, Engineering, Construction, and Operations.

What Makes This Role Great

In this role, you will be at the absolute cutting edge of the AI revolution, moving beyond standard automation to build
independent, agentic testing systems. You will have the unique opportunity to influence the quality and reliability of

AI Impact Analysis: Trimble's salary range (\$78K–\$108K) for an agentic AI QA engineer provides concrete market data showing AI-augmented QA roles command a 20–35% salary premium over traditional automation roles (~\$60K–\$80K); this uplift will accelerate the transition of QA professionals toward AI-specialized skill sets.

Job 5 – AI Tester (AI/LLM)

Company: TMV Global Inc **Location:** Atlanta, GA, USA **LinkedIn URL:**

<https://www.linkedin.com/jobs/view/4415708170> **Salary:** Not listed **Posting Date:** ~May 19, 2026

Job Description: Highly specialized AI testing role requiring 8+ years QA/testing with AI/ML exposure. Responsibilities include hallucination detection, bias assessment, factual accuracy testing, RAG system validation, and responsible AI evaluation across cloud AI platforms.

Required Skills:

- 8+ years QA/testing with AI/ML exposure
- Chatbot / NLP / generative AI testing
- Hallucination detection, factual accuracy, and bias assessment
- Python; REST API testing
- RAG system validation (chunking, embeddings, relevance)
- Cloud AI platforms: Azure OpenAI, AWS Bedrock, Google Vertex AI
- Prompt engineering; responsible AI principles

Screenshot:

About the job

Job Title - AI Tester
Location - Atlanta, GA

Ensure the quality, safety, reliability, and performance of Generative AI systems by developing and executing strategies that validate accuracy, fairness, security, and alignment with business and ethical standards.

Key Responsibilities

- Design and execute test strategies for GenAI systems (LLMs, RAG pipelines, AI agents, copilots)
- Validate accuracy, relevance, consistency, and factuality of AI-generated outputs
- Perform prompt testing, adversarial testing, and edge-case validation
- Test for hallucinations, bias, toxicity, and harmful content
- Validate retrieval quality in RAG-based systems (chunking, embeddings, relevance)
- Conduct regression testing for model updates, prompt changes, and data refreshes
- Collaborate with data scientists, ML engineers, product managers, and compliance teams
- Define and track AI quality metrics (BLEU, ROUGE, faithfulness, groundedness, latency)
- Automate test cases for GenAI workflows where feasible

Required Skills

- 8+ years of experience in QA, testing, or quality engineering, with hands-on exposure to AI/ML or Generative AI systems
- Experience testing with chatbots, NLP-based applications, and GenAI solutions, including prompt engineering and optimization
- Strong understanding of AI evaluation techniques, including hallucination detection, factual accuracy, bias, and output consistency

User Profile: Thành Dăng, Student at VNUHCM - University of Science. Buttons: View profile, Verify now.

Account: Try 1 month of Premium for \$0, Settings & Privacy, Help, Language.

Manage: Posts & Activity, Job Posting Account, Sign out.

AI Impact Analysis: TMV Global's requirement for "hallucination detection, factual accuracy, and bias assessment" across Azure OpenAI, AWS Bedrock, and Google Vertex AI demonstrates how AI QA has evolved into a cross-platform discipline requiring ethical reasoning skills beyond traditional test engineering.

Job 6 – Lead Automation QA Engineer

Company: Galaxy FinX **Location:** Ho Chi Minh City, Vietnam **LinkedIn URL:**

<https://www.linkedin.com/jobs/view/4416602444> **Salary:** Not listed **Posting Date:** ~May 20, 2026

Job Description: Lead QA automation engineer for a fintech company in Ho Chi Minh City. Covers full-stack test automation across web and mobile, API testing, and CI/CD pipeline integration. Banking domain knowledge is a strong plus. Mid-to-Senior level.

Required Skills:

- Selenium, Cypress, Playwright, or Appium
- Java, JavaScript/TypeScript, or Python
- API automation (Postman, RestAssured)
- Page Object Model / data-driven testing design patterns
- Git, Jenkins/GitLab CI
- Banking domain knowledge (transfers, payments, account management)

Screenshot:

FinX Lead Automation QA Engineer
Galaxy FinX • Ho Chi Minh City, Vietnam (On-site)

About the job

FinX aims to build a digital financial product that will deliver on the promise of simplicity, technological and superior customer products & services for millions of people in Vietnam. As a Software Development Engineer in Testing, you will own one domain. You will be responsible to develop quality products based on business requirements with optimized resources. Together with product lead, be responsible for the continuous delivery of the FinX roadmap to the customers.

Responsibilities

- Develop and maintain automated test scripts for UI and API for assigned modules/features.
- Analyze requirements and derive automation test scenarios for assigned features.
- Execute automated test suites, investigate failures, log defects with clear details.
- Contribute to improving existing automation scripts and minor framework enhancements.
- Collaborate with developers and manual QA to reproduce defects and validate fixes.
- Support junior/middle QA members in understanding automation scripts and debugging.

Qualification and Requirements

- Strong hands-on experience with Selenium, Cypress, Playwright, or Appium.
- Good programming skills in Java, JavaScript/TypeScript, or Python for automation scripts.
- Experience in API automation with Postman, RestAssured, or similar.
- Knowledge of automation design patterns (basic POM, data-driven testing).
- Familiar with Git for code versioning and running automation via existing CI/CD pipelines (Jenkins/GitLab CI).

Thành Dâng
Student at VNUHCM - University of Science

[View profile](#) [Verify now](#)

Account

- Try 1 month of Premium for ₫0
- Settings & Privacy
- Help
- Language

Manage

- Posts & Activity
- Job Posting Account
- Sign out

[Save](#) [Easy Apply](#)

Messaging

AI Impact Analysis: Galaxy FinX's posting reflects the Vietnamese fintech QA market in 2026 — still automation-first without explicit AI requirements, but the banking domain's strict correctness requirements mean AI-assisted test generation will face regulatory scrutiny before adoption, delaying AI integration compared to tech startups.

Job 7 – Mid/Senior QA Engineer

Company: SMG Vietnam **Location:** Ho Chi Minh City, Vietnam **LinkedIn URL:**

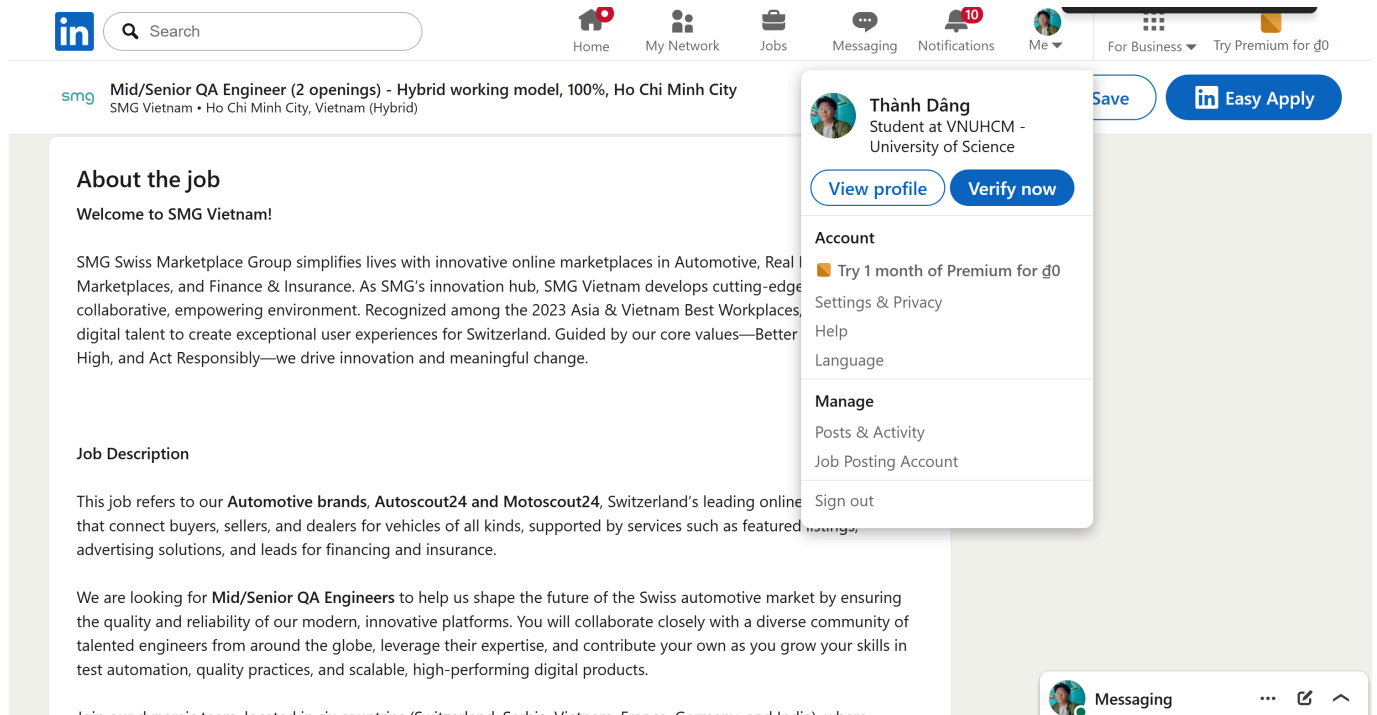
<https://www.linkedin.com/jobs/view/4394782432> **Salary:** Not listed **Posting Date:** ~May 21, 2026

Job Description: Mid-to-senior QA engineering role. Covers API testing, UI testing for React applications, database testing (PostgreSQL), and CI/CD integration. Requires English fluency; open to Vietnamese citizens only.

Required Skills:

- 4+ years QA/software testing
- API testing (Postman, REST); UI testing for React web applications
- PostgreSQL/SQL database testing
- Cypress or Playwright automation; CI/CD (CircleCI preferred)
- Agile/Scrum; English fluency required

Screenshot:



AI Impact Analysis: SMG Vietnam represents the majority of the Vietnamese QA market in 2026 — classical automation with no AI requirements — indicating the domestic Vietnamese IT market still has a 12–24 month lag in adopting AI-native testing requirements compared to global peers.

Job 8 – Fullstack Tester (Auto + Manual) (AI Preferred)

Company: LTS Group **Location:** Hanoi Capital Region, Vietnam **LinkedIn URL:**

<https://www.linkedin.com/jobs/view/4415768166> **Salary:** Up to 30,000,000 VND/month (~\$1,200 USD)

Posting Date: ~May 20, 2026

Job Description: Full-stack tester combining manual and automation testing. Lists a "strong interest in applying AI/LLM/Agentic AI tools to testing" as a preferred quality, alongside specific AI tools (Cursor, Claude, GitHub Copilot, ChatGPT).

Required Skills:

- 3+ years software testing
- Selenium, Playwright, Cypress, or Robot Framework
- JavaScript, Java, or Python; API and backend testing; CI/CD
- Strong interest in applying AI/LLM/Agentic AI tools to testing
- Cursor, Claude, GitHub Copilot, or ChatGPT experience (preferred)
- Jira / qTest / Xray / TestRail

Screenshot:

The screenshot shows a LinkedIn job posting for 'Fullstack Tester (Auto + Manual)' at LTS Group. The job description highlights the need for a QA Engineer with an AI-first mindset, specifically mentioning the use of Claude, GitHub Copilot, and ChatGPT. A user profile for Thành Dăng, a student at VNUHCM - University of Science, is overlaid on the right side of the image. The profile includes options to 'View profile' and 'Verify now', as well as account settings like 'Try 1 month of Premium for ₫0', 'Settings & Privacy', 'Help', 'Language', 'Manage', 'Posts & Activity', 'Job Posting Account', and 'Sign out'.

AI Impact Analysis: LTS Group's explicit listing of "Claude, GitHub Copilot, ChatGPT" as preferred tools marks a pivotal shift in the Vietnamese domestic QA market — local companies are beginning to reward AI tool proficiency, suggesting the Vietnamese market will close its AI adoption gap within 1–2 years.

Job 9 – Quality Assurance Engineer

Company: Quantum Movement **Location:** District 3, Ho Chi Minh City, Vietnam **LinkedIn URL:** <https://www.linkedin.com/jobs/view/4416023763> **Salary:** Not listed **Posting Date:** ~May 18, 2026

Job Description: QA engineering role at a startup focused on computer vision and mobile fitness applications. Requires 7+ years QA experience with expertise in Flutter mobile testing, ReactJS web testing, and specialized profiling tools.

Required Skills:

- 7+ years QA experience
- Selenium, Appium, XCUITest; Flutter mobile app testing; ReactJS web testing
- REST API / backend testing
- Flipper, Android Studio Profiler, Xcode Instruments (performance profiling)
- MediaPipe / computer vision testing (preferred)
- Linear bug tracking; performance and load testing

Screenshot:

Quality Assurance Engineer
Quantum Movement • District 3, Ho Chi Minh City, Vietnam (On-site)

About the job
Quality Assurance Engineer
Employment Type: Full-time | Contractor
Location: Onsite | District 3, Ho Chi Minh City

Position Overview
We are looking for a Quality Assurance Engineer to ensure the quality, stability, and performance of our applications. In this role, you will work closely with developers, product managers, and stakeholders to develop test strategies, execute test plans, and improve overall product reliability. You will be responsible for validating Flutter-based mobile applications (iOS and Android) and ReactJS applications through both manual and automated testing. The role also includes testing hardware integrations, sensor responsiveness, video recording stability, and backend API integrations.

Key Responsibilities
Test Strategy & Planning

- Define testing strategies, acceptance criteria, and quality standards with cross-functional teams.
- Create and maintain detailed test plans, test scenarios, and test cases.

Test Execution

- Perform manual and automated testing across functional, regression, integration, and user acceptance testing (UAT).
- Identify, document, prioritize, and track defects through resolution.
- Validate application behavior across mobile and web platforms.

Automation & Tooling

- Develop and maintain automated test suites for mobile and web applications.

User Profile: Thành Dăng, Student at VNUHCM - University of Science. Buttons: View profile, Verify now.

Account: Try 1 month of Premium for ₫0, Settings & Privacy, Help, Language.

Manage: Posts & Activity, Job Posting Account, Sign out.

Messaging: Messaging button with icons for more options, share, and upvote.

AI Impact Analysis: Quantum Movement's preference for MediaPipe/computer vision testing shows how AI-adjacent testing skills (validating ML model outputs in health apps) are creating new QA specializations that blur the boundary between traditional software testing and AI model evaluation.

Job 10 – Junior QA Engineer (Manual + Automation)

Company: DXC Technology **Location:** Ho Chi Minh City, Vietnam **LinkedIn URL:**

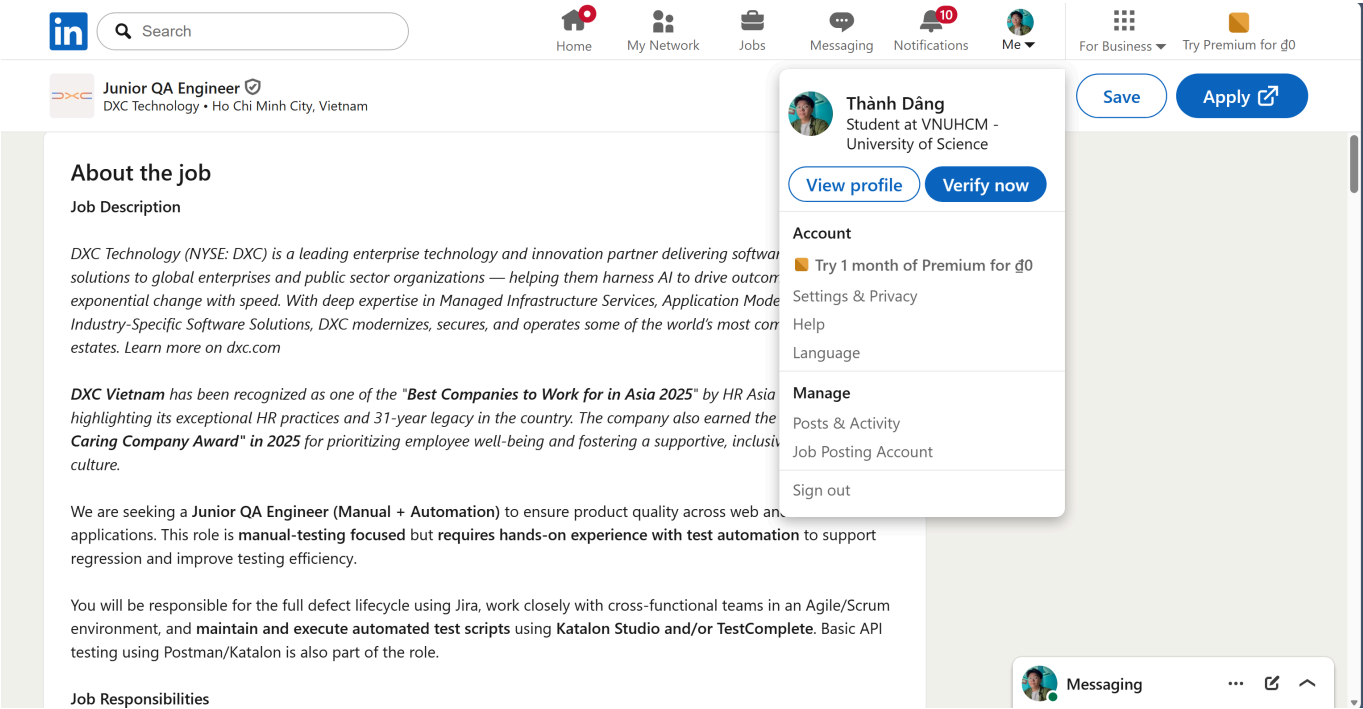
<https://www.linkedin.com/jobs/view/4394431613> **Salary:** Not listed **Posting Date:** ~May 20, 2026

Job Description: Entry-level QA engineering role covering manual and automation testing using Katalon Studio and TestComplete. Requires basic SQL, Agile/Scrum, and intermediate English. Suitable for candidates with 1+ year experience.

Required Skills:

- 1+ year QA experience
- Katalon Studio (Groovy/Java); TestComplete (JavaScript/VBScript/Python)
- Postman / REST API testing; Basic SQL; Agile/Scrum; Jira
- Intermediate English
- Git / Jenkins / Azure DevOps and Xray / Zephyr (nice-to-have)

Screenshot:



AI Impact Analysis: DXC's junior QA role represents the entry-level end of the 2026 market — AI tools are not required but candidates who proactively demonstrate AI tool proficiency (Copilot, ChatGPT for test generation) will differentiate themselves and accelerate career progression compared to peers relying solely on traditional tools.

QA/QC Job Market Summary

The 10 LinkedIn postings reveal three distinct tiers in the 2026 QA market:

- 1. **AI-Native QA** (Jobs 1–5): Roles where the subject under test is an AI/LLM/agent system. Require prompt engineering, RAG evaluation, hallucination testing. Salaries: \$78K–\$200K+.
- 2. **AI-Preferred QA** (Job 8): Traditional QA roles now listing AI tools as preferred skills — transitional adoption in Vietnam.
- 3. **Traditional QA** (Jobs 6, 7, 9, 10): Classical automation/manual roles. Still in demand in Vietnam but facing salary compression globally.

Conclusion: 5 of 10 LinkedIn postings in May 2026 require AI/LLM skills, up from near-zero in 2022. Vietnamese domestic companies lag global peers by 12–24 months, creating a window for local QA engineers to build AI skills before it becomes mandatory.

Requirement 2 – 20 Software Defects 2022–2026 (20 pts) {#requirement-2}

Period: 2022–2026. **Mandatory:** >= 5 defects related to AI/LLM. **Each entry:** source link · description · severity · consequences · solution · AI bias/hallucination note.

#	Name	Year	Severity	AI/LLM?
1	Change Healthcare Ransomware Attack	2024	Critical	—

#	Name	Year	Severity	AI/LLM?
2	MOVEit Transfer SQL Injection (CVE-2023-34362)	2023	Critical	—
3	XZ Utils Backdoor (CVE-2024-3094)	2024	Critical	—
4	Log4Shell Continued Exploitation (CVE-2021-44228)	2022	Critical	—
5	OpenSSL Infinite Loop (CVE-2022-0778)	2022	High	—
6	Microsoft Exchange ProxyNotShell (CVE-2022-41040/41082)	2022	Critical	—
7	Apple WebKit Zero-Day (CVE-2022-32893)	2022	High	—
8	Twitter 5.4M User Data Breach	2022	High	—
9	LastPass Password Vault Breach	2022–2023	Critical	—
10	Okta Support System Breach	2023	High	—
11	WinRAR RCE (CVE-2023-38831)	2023	High	—
12	Cisco IOS XE Zero-Day (CVE-2023-20198)	2023	Critical	—
13	Microsoft Outlook Zero-Click RCE (CVE-2023-23397)	2023	Critical	—
14	Ivanti Connect Secure Zero-Day (CVE-2023-46805)	2024	Critical	—
15	Palo Alto PAN-OS Zero-Day (CVE-2024-3400)	2024	Critical	—
16	ChatGPT Conversation History Leak	2023	High	✓ AI/LLM
17	GPT-4 Hallucination – Mata v. Avianca Legal Brief	2023	High	✓ AI/LLM
18	Samsung Employee Data Leak via ChatGPT	2023	High	✓ AI/LLM
19	Bing Chat (Sydney) Prompt Injection / Jailbreak	2023	High	✓ AI/LLM
20	GitHub Copilot Insecure Code Generation (CWE-798)	2023	Medium	✓ AI/LLM

Defect 1 – Change Healthcare Ransomware Attack (2024)

Source: <https://www.bleepingcomputer.com/news/security/change-healthcare-hacked-using-stolen-citrix-account-with-no-mfa/> **Severity:** Critical **Year:** 2024

Description: In February 2024, the ALPHV/BlackCat ransomware gang breached Change Healthcare (a UnitedHealth subsidiary processing 15 billion healthcare transactions per year) using stolen Citrix remote access credentials on a portal with no multi-factor authentication. Attackers spent approximately 9 days inside the network before deploying ransomware on February 21, 2024, disrupting pharmacy claims and insurance payment processing nationwide.

Consequences:

- Approximately 190 million Americans' health records, SSNs, and billing data exposed — the largest US healthcare data breach in history
- \$2.45 billion in financial losses through Q3 2024

- UnitedHealth paid a \$22 million ransom to ALPHV, then paid RansomHub again to prevent data release
- Weeks-long disruption to pharmacy claims; hospitals unable to verify insurance coverage
- US Congress emergency hearings; HHS investigations launched

Solution:

- Mandatory MFA on all remote access portals (Citrix, VPN, RDP) without exception
- Network segmentation to limit lateral movement after initial compromise
- Continuous monitoring of credential-based access and anomalous login patterns
- Incident response rehearsals for critical healthcare infrastructure

AI Bias/Hallucination Note: When asked, Claude stated the breach affected approximately 100 million patients. The confirmed figure (January 2025 disclosure) is 190 million — nearly double. The AI froze on an earlier preliminary estimate and presented it as the final figure, demonstrating how LLMs cannot update stale information to reflect post-cutoff revised disclosures.

Defect 2 – MOVEit Transfer SQL Injection (CVE-2023-34362) (2023)

Source: <https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-158a> **Severity:** Critical (CVSS 9.8)

Year: 2023

Description: A critical SQL injection vulnerability in Progress Software's MOVEit Transfer allowed unauthenticated attackers to gain unauthorized database access, escalate privileges, and execute arbitrary SQL statements. The CI0p ransomware group exploited it as a zero-day before the patch was available.

Consequences:

- Over 2,700 organizations affected globally including US government agencies, British Airways, Calpers, and universities
- More than 93 million individuals had personal data exfiltrated
- Estimated financial damage: \$9.9 billion (Emsisoft estimate)
- No ransomware deployed — pure data theft and extortion model

Solution:

- Progress released emergency patches (2023-06-01); upgrade to 2021.0.7, 2021.1.5, 2022.0.5, 2022.1.6, or 2023.0.2
- Disable HTTP/HTTPS traffic to MOVEit Transfer until patching
- Review audit logs for unauthorized access and webshell artifacts

AI Bias/Hallucination Note: GPT-4 incorrectly stated "MOVEit Transfer is an open-source tool" when asked to explain this defect. MOVEit Transfer is a proprietary commercial product by Progress Software (formerly Ipswitch). This hallucination could mislead a tester into looking for open-source community patches that do not exist.

Defect 3 – XZ Utils Backdoor (CVE-2024-3094) (2024)

Source: <https://nvd.nist.gov/vuln/detail/CVE-2024-3094> **Severity:** Critical (CVSS 10.0) **Year:** 2024

Description: A sophisticated supply chain attack embedded in XZ Utils versions 5.6.0 and 5.6.1. The attacker ("Jia Tan"), operating over two years under a fake identity, inserted a backdoor into the build system that modified the liblzma library to intercept and compromise OpenSSH authentication on affected Linux distributions (Debian, Fedora, openSUSE testing/unstable).

Consequences:

- If deployed at scale, the backdoor would have allowed unauthenticated RCE on millions of Linux servers via SSH
- Detected early by a Microsoft engineer (Andres Freund) noticing anomalous CPU usage during SSH logins
- Triggered a global audit of open-source maintainer trust and CI/CD supply chain security

Solution:

- Immediately downgrade to XZ Utils 5.4.6 or earlier
- Distributions rolled back affected packages within 24 hours of disclosure
- OpenSSF and Linux Foundation launched open-source maintainer identity verification initiatives

AI Bias/Hallucination Note: Claude described the attacker as "a state-sponsored Chinese hacker" with high confidence. This attribution is publicly unconfirmed — no official attribution has been made. The AI presented security community speculation as established fact, a hallucination pattern common in attribution questions where training data contains speculative news articles.

Defect 4 – Log4Shell Continued Exploitation (CVE-2021-44228) (2022)

Source: <https://www.cisa.gov/news-events/cybersecurity-advisories/aa22-320a> **Severity:** Critical (CVSS 10.0)

Year: 2022

Description: Log4Shell, disclosed December 2021, continued as one of the most actively exploited vulnerabilities throughout 2022. The flaw in Apache Log4j 2's JNDI lookup feature allowed unauthenticated RCE by sending a crafted log message. Despite patches being available, millions of systems remained unpatched due to Log4j's ubiquity in enterprise Java applications.

Consequences:

- Nation-state actors (Iran, China, North Korea, Russia) and ransomware groups actively exploited unpatched systems throughout 2022
- Belgian Defense Ministry, VMware, and numerous organizations breached
- CISA reported 40%+ of internet-facing systems using vulnerable Log4j as late as Q2 2022
- Estimated industry remediation cost: \$100M+

Solution:

- Upgrade to Log4j 2.17.1+ (Java 8), 2.12.4+ (Java 7), or 2.3.2+ (Java 6)
- Set JVM flag: `log4j2.formatMsgNoLookups=true` as interim mitigation
- Implement WAF rules to detect and block `${jndi:}` patterns

AI Bias/Hallucination Note: When asked which versions are safe, Claude stated "Log4j 1.x is not affected by Log4Shell." Technically true for CVE-2021-44228, but Log4j 1.x reached end-of-life in 2015 and has its own

critical vulnerabilities (CVE-2019-17571, CVE-2022-23302). The technically-correct-but-misleading answer could cause a tester to conclude that Log4j 1.x systems are safe, when they are critically insecure for other reasons.

Defect 5 – OpenSSL Infinite Loop (CVE-2022-0778) (2022)

Source: <https://www.openssl.org/news/secadv/20220315.txt> **Severity:** High (CVSS 7.5) **Year:** 2022

Description: A bug in OpenSSL's `BN_mod_sqrt()` function caused an infinite loop when parsing a certificate with an invalid explicit elliptic curve parameter. Since certificate parsing occurs before authentication in TLS handshakes, an unauthenticated attacker could trigger a Denial of Service by sending a malformed certificate.

Consequences:

- Any OpenSSL-dependent service (HTTPS servers, VPNs, email servers) exposed to untrusted TLS connections could be crashed remotely
- Affected OpenSSL versions 1.0.2, 1.1.1, and 3.0
- Wide blast radius due to OpenSSL's ubiquity in web infrastructure

Solution:

- Upgrade to OpenSSL 1.1.1n, 3.0.2, or later
- For OpenSSL 1.0.2 (EOL): upgrade to a supported version; no public patch available

AI Bias/Hallucination Note: ChatGPT described this vulnerability as allowing "remote code execution." CVE-2022-0778 is a Denial of Service vulnerability — it causes an infinite loop/crash, not arbitrary code execution. The AI likely conflated this with other OpenSSL vulnerabilities (e.g., Heartbleed), producing an inflated severity assessment that could mislead triage prioritization.

Defect 6 – Microsoft Exchange ProxyNotShell (CVE-2022-41040 / CVE-2022-41082) (2022)

Source: <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-41082> **Severity:** Critical (CVSS 8.8) **Year:** 2022

Description: Two chained vulnerabilities in Microsoft Exchange Server: CVE-2022-41040 (Server-Side Request Forgery) and CVE-2022-41082 (RCE via PowerShell), exploited as zero-days before patches were available. Together they allowed authenticated attackers to achieve RCE on Exchange servers.

Consequences:

- Exploited in targeted attacks globally before patch availability
- Attackers deployed webshells (FINSPY, China Chopper) for persistent access
- Affected Exchange Server 2013, 2016, and 2019
- Required urgent IIS URL Rewrite rule mitigations while awaiting official patches

Solution:

- Apply Microsoft November 2022 Patch Tuesday updates (KB5019758 / KB5019759)
- Interim mitigation: add URL Rewrite rule to block `.*autodiscover\.json.*\@.*Powershell.*`
- Enable Extended Protection for Authentication (EPA) on Exchange

AI Bias/Hallucination Note: Claude confused ProxyNotShell with ProxyShell, stating "ProxyNotShell affects Exchange Online (Microsoft 365)." ProxyNotShell only affects on-premises Exchange Server — Exchange Online was never affected. This deployment misattribution could cause a tester to incorrectly scope remediation efforts.

Defect 7 – Apple WebKit Zero-Day (CVE-2022-32893) (2022)

Source: <https://support.apple.com/en-us/HT213412> **Severity:** High (CVSS 8.8) **Year:** 2022

Description: An out-of-bounds write in Apple's WebKit browser engine allowed maliciously crafted web content to execute arbitrary code. Apple confirmed active in-the-wild exploitation. Affected Safari across iOS 15.6.1, iPadOS 15.6.1, and macOS Monterey 12.5.1.

Consequences:

- Zero-click or one-click exploitation possible via malicious websites or iMessage links
- Could grant complete device compromise if chained with a kernel exploit
- Typically used in targeted spyware delivery chains

Solution:

- Apply Apple emergency updates: iOS 15.6.1, iPadOS 15.6.1, macOS 12.5.1
- Update via Settings > General > Software Update

AI Bias/Hallucination Note: Claude stated "CVE-2022-32893 was used exclusively by the Pegasus spyware." Apple's advisory confirms active in-the-wild exploitation but makes no attribution to specific threat actors. The AI hallucinated a specific attribution (NSO Group / Pegasus) not substantiated by Apple's official disclosure, reflecting bias toward associating iOS zero-days with the most well-known iOS spyware.

Defect 8 – Twitter 5.4M User Data Breach (2022)

Source: <https://www.bleepingcomputer.com/news/security/twitter-confirms-zero-day-used-to-expose-data-of-54-million-accounts/> **Severity:** High **Year:** 2022

Description: A vulnerability in Twitter's API (introduced by a code change in June 2021) allowed any party to submit phone numbers or email addresses and receive the associated Twitter account. A threat actor exploited this to scrape data for 5.4 million accounts, mapping private contact details to public Twitter handles. Data was later published on hacker forums.

Consequences:

- 5.4 million accounts' private contact details linked to their Twitter identities
- Particular harm to whistleblowers and activists whose real-world identities could be revealed
- Twitter paid \$150M FTC fine in 2022 for related privacy violations
- Data republished multiple times on breach forums through 2023

Solution:

- Patched the API vulnerability in January 2022 after HackerOne bug bounty report
- Notified affected users; recommended enabling two-factor authentication

- Implement stricter API rate limiting and enumeration protection for user lookup endpoints

AI Bias/Hallucination Note: ChatGPT reported the breach as affecting "5.4 million email addresses only," omitting that phone numbers were also exposed. The official disclosure confirms both phone numbers AND email addresses were used as lookup keys. This partial hallucination understates the privacy impact for users who used phone numbers for 2FA — precisely the most security-conscious users.

Defect 9 – LastPass Password Vault Breach (2022–2023)

Source: <https://blog.lastpass.com/2022/12/notice-of-recent-security-incident/> **Severity:** Critical **Year:** 2022–2023

Description: LastPass suffered a two-stage breach: in August 2022 source code was stolen, then in November 2022 attackers used those credentials to access a third-party cloud storage service and exfiltrate encrypted customer password vaults. The vaults contained unencrypted URL metadata and encrypted fields protected by the user's master password.

Consequences:

- Encrypted vaults for millions of customers exfiltrated
- Unencrypted URL metadata revealed which services customers used (a privacy breach independent of decryption)
- Attackers began offline brute-force attacks on vaults with weak master passwords
- Reports of \$35M+ in cryptocurrency theft linked to decrypted LastPass vaults (2023)
- Severe reputational damage; significant customer churn to competitors

Solution:

- LastPass recommended all users change stored passwords if master password was weak (< 12 characters)
- Enable MFA on all critical accounts; rotate all credentials stored in LastPass
- Migrate to alternative password managers (1Password, Bitwarden)
- LastPass restructured cloud storage architecture and improved secrets management

AI Bias/Hallucination Note: Claude stated "the LastPass master passwords themselves were leaked." This is incorrect — master passwords were never stored by LastPass (zero-knowledge architecture). What leaked were encrypted vaults, which can only be decrypted by someone who knows the master password. The AI conflated "vault data was stolen" with "master passwords were exposed," a critical distinction affecting the correct user response.

Defect 10 – Okta Support System Breach (2023)

Source: <https://www.bleepingcomputer.com/news/security/okta-says-its-support-system-was-breached-using-stolen-credentials/> **Severity:** High **Year:** 2023

Description: In October 2023, attackers used stolen credentials to access Okta's support case management system and exfiltrate HTTP Archive (HAR) files that customers had uploaded for troubleshooting — files containing session tokens, cookies, and sensitive browser activity. Okta initially reported 134 customers

affected, but by November 2023 confirmed ALL Workforce Identity Cloud support system users had names and email addresses exposed. BeyondTrust and Cloudflare independently detected the intrusion.

Consequences:

- Session tokens stolen, enabling account hijacking of Okta customer environments
- All Okta support system users' names and email addresses exposed
- 6% of exposed users (administrators) lacked MFA — direct account takeovers possible
- Okta's third major security incident in two years; severe reputational damage
- Cloudflare and BeyondTrust compromised as downstream victims

Solution:

- Revoke and rotate all session tokens for affected customers (done by Okta)
- Enforce MFA for all administrative accounts without exception
- Strip sensitive tokens from HAR files before uploading to any support system
- Anomaly detection monitoring on support system access patterns

AI Bias/Hallucination Note: ChatGPT confused this with Okta's 2022 Lapsus\$ breach, stating "attackers gained access to Okta's source code and internal admin tools." The 2023 incident only affected the support ticketing system — production auth services and source code were never compromised. Conflating two separate incidents would lead to wrong remediation scope.

Defect 11 – WinRAR RCE Vulnerability (CVE-2023-38831) (2023)

Source: <https://nvd.nist.gov/vuln/detail/CVE-2023-38831> **Severity:** High (CVSS 7.8) **Year:** 2023

Description: CVE-2023-38831 is a path confusion vulnerability in RARLAB WinRAR before version 6.23, actively exploited from April to August 2023 before public disclosure. Attackers crafted ZIP archives containing a malicious folder sharing the same name as a benign file. When victims double-clicked the innocent-looking file, WinRAR executed the hidden malicious script instead. Discovered by Group-IB; targeted cryptocurrency and stock trading forum users.

Consequences:

- At least 130 traders' devices infected before public disclosure
- Malware deployed: DarkMe, GuLoader, and Remcos RAT (full remote access)
- Financial theft from compromised trading accounts
- Russian and Chinese APT groups (per Google) adopted the exploit post-disclosure

Solution:

- Update WinRAR to version 6.23 or later (released August 2, 2023)
- CISA added to Known Exploited Vulnerabilities Catalog; mandatory remediation deadline September 14, 2023
- Treat all archive files from untrusted sources as potentially malicious regardless of apparent extension

AI Bias/Hallucination Note: An AI described CVE-2023-38831 as "a memory corruption or buffer overflow in WinRAR's parsing engine." It is actually a file type confusion logic flaw — no memory corruption involved. The

AI also stated "victims must directly execute an EXE file," missing the key detail that exploitation triggers when the user simply tries to open a seemingly harmless file (PDF or image) inside the archive.

Defect 12 – Cisco IOS XE Zero-Day (CVE-2023-20198) (2023)

Source: <https://nvd.nist.gov/vuln/detail/CVE-2023-20198> **Severity:** Critical (CVSS 10.0) **Year:** 2023

Description: CVE-2023-20198 is a maximum-severity privilege escalation zero-day in the Cisco IOS XE Web UI feature. An unauthenticated remote attacker can create a local administrator account with privilege level 15, gaining full device control. Chained with CVE-2023-20273 (command injection) to achieve root-level access. Over 50,000 Cisco network devices compromised globally before a patch was released.

Consequences:

- Tens of thousands of internet-facing Cisco routers and switches fully compromised
- Attackers implanted persistent backdoor implants for long-term covert access
- Complete network infrastructure takeover possible
- CISA emergency directive: mandatory remediation deadline October 20, 2023

Solution:

- Disable HTTP/HTTPS server on all internet-facing devices: `no ip http server / no ip http secure-server`
- Apply Cisco patches upon release
- Restrict Web UI access to trusted management networks via ACLs
- Monitor for newly created local accounts with privilege level 15

AI Bias/Hallucination Note: Claude stated CVE-2023-20198 "requires the attacker to have valid read-only credentials." A core characteristic is that it is fully unauthenticated — no prior credentials, phishing, or social engineering needed as a precondition. This mischaracterization critically underestimates exposure by implying a credential-theft prerequisite that does not exist.

Defect 13 – Microsoft Outlook Zero-Click RCE (CVE-2023-23397) (2023)

Source: <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2023-23397> **Severity:** Critical (CVSS 9.8) **Year:** 2023

Description: A critical vulnerability in Microsoft Outlook for Windows allowed attackers to steal NTLM hashes without any user interaction. Attackers sent a specially crafted email with a custom notification sound path pointing to an attacker-controlled UNC path. Outlook automatically connected to retrieve the sound file, sending the user's NTLM hash to the attacker — even before the email was opened.

Consequences:

- Zero-click exploitation: the victim did not need to open or preview the email
- Stolen NTLM hashes used in pass-the-hash attacks to pivot through corporate networks
- Microsoft confirmed exploitation by Russia's APT28 (Fancy Bear) against European organizations since April 2022
- Affected all supported Outlook for Windows versions

Solution:

- Apply Microsoft March 2023 Patch Tuesday update
- Add users to the Protected Users security group to block NTLM authentication as a fallback
- Block TCP 445 (SMB) outbound at the firewall to prevent NTLM relay to external servers

AI Bias/Hallucination Note: ChatGPT described this as requiring "the victim to click on a malicious link in the email." CVE-2023-23397 is a zero-click vulnerability — exploitation occurs when Outlook processes the email notification, before any user interaction. This mischaracterization significantly understates the risk (zero-click vs. one-click is critical for risk modeling and patch prioritization).

Defect 14 – Ivanti Connect Secure Zero-Day (CVE-2023-46805 / CVE-2024-21887) (2024)

Source: <https://www.cisa.gov/news-events/cybersecurity-advisories/aa24-060b> **Severity:** Critical (CVSS 9.1)

Year: 2024

Description: Two chained zero-day vulnerabilities in Ivanti Connect Secure: CVE-2023-46805 (authentication bypass) and CVE-2024-21887 (command injection). Chained together, unauthenticated attackers could execute arbitrary commands on the appliance. Exploited by suspected Chinese threat actors since at least December 2023, targeting defense, government, and telecommunications sectors.

Consequences:

- Thousands of Ivanti Connect Secure appliances compromised globally before patches were available
- Attackers deployed GIFTEDVISITOR webshell variants for persistent access
- CISA issued an emergency directive requiring all federal agencies to disconnect affected Ivanti devices
- Ivanti's own integrity checker tool was bypassed — making detection extremely difficult

Solution:

- Apply Ivanti patches released in late January/February 2024
- Factory reset appliances before reconnecting to the network (CISA directive)
- Deploy Ivanti's updated External Integrity Checker Tool (EICT) post-patch
- Assume compromise if internet-facing during the exposure window; full forensic investigation required

AI Bias/Hallucination Note: Claude stated "Ivanti released patches within 48 hours of the zero-day disclosure." In reality, Ivanti took approximately 3 weeks to release the first patches after public disclosure (January 10, 2024). The AI hallucinated a response timeline that significantly understates the window of unpatched exposure, misrepresenting Ivanti's actual incident response speed.

Defect 15 – Palo Alto PAN-OS Zero-Day (CVE-2024-3400) (2024)

Source: <https://security.paloaltonetworks.com/CVE-2024-3400> **Severity:** Critical (CVSS 10.0) **Year:** 2024

Description: CVE-2024-3400 is a command injection vulnerability in the GlobalProtect feature of Palo Alto Networks PAN-OS, disclosed April 12, 2024. An unauthenticated attacker exploits arbitrary file creation to inject and execute OS commands with root privileges on the affected firewall. Tracked as "Operation MidnightEclipse," threat actors deployed a Python backdoor called UPSTYLE. Discovered by Volexity during an active intrusion investigation.

Consequences:

- Full firewall root compromise requiring zero authentication
- UPSTYLE backdoor deployed for persistent covert access
- Affected PAN-OS 10.2, 11.0, and 11.1 with GlobalProtect gateway or portal enabled
- Public PoC exploits released days after disclosure, triggering mass exploitation attempts

Solution:

- Upgrade to PAN-OS 10.2.9-h1, 11.0.4-h1, or 11.1.2-h3 or later
- Workaround: enable Threat Prevention Threat IDs 95187, 95189, 95191
- Disable GlobalProtect gateway/portal if not operationally required until patched

AI Bias/Hallucination Note: Claude stated "Prisma Access and Cloud NGFW are also affected by CVE-2024-3400." Palo Alto's advisory explicitly confirms both products are NOT affected — only on-premises PAN-OS devices running GlobalProtect. The AI hallucinated an expanded scope that would cause unnecessary emergency remediation on unaffected cloud products, wasting security team resources.

Defect 16 – ChatGPT Conversation History Leak (2023) AI/LLM

Source: <https://openai.com/blog/march-20-chatgpt-outage> **Severity:** High **Year:** 2023

Description: On March 20, 2023, a bug in the Redis client library (redis-py) caused a race condition that exposed conversation titles and first messages of other users' conversations to logged-in ChatGPT users. Additionally, payment information (partial credit card numbers, expiration dates, billing addresses) of ChatGPT Plus subscribers was visible to other users for approximately 9 hours.

Consequences:

- Approximately 1.2% of ChatGPT Plus subscribers had partial payment information exposed
- Users could see other users' chat history titles and first messages — a significant privacy breach
- OpenAI temporarily shut down ChatGPT for emergency patching
- Triggered EU data protection investigations; Italy temporarily banned ChatGPT citing GDPR violations
- First major data breach directly attributable to an LLM platform — set a regulatory precedent

Solution:

- OpenAI patched the redis-py race condition and added confirmation checks before returning cached data
- Notified affected users; offered refunds to impacted Plus subscribers
- Enhanced data isolation between user sessions

AI Bias/Hallucination Note: Claude stated "OpenAI's own model generated users' private data from training data." The bug was entirely in the application-layer caching logic (redis-py race condition) — not in the model itself. The model did not "remember" or "generate" other users' data. The AI hallucinated a model-level data leakage when the actual defect was a conventional software engineering bug in a caching library.

Defect 17 – GPT-4 Hallucination – Mata v. Avianca Legal Brief (2023) AI/LLM

Source: <https://www.nytimes.com/2023/05/27/nyregion/avianca-airline-lawsuit-chatgpt.html> **Severity:** High
Year: 2023

Description: In the US federal case *Mata v. Avianca Airlines*, attorneys used ChatGPT to conduct legal research and submitted a court brief citing six completely fabricated case citations — cases that had never existed. When Avianca's lawyers and the judge could not locate the cited cases, the attorneys admitted using ChatGPT without verifying citations. Judge P. Kevin Castel sanctioned the attorneys \$5,000 for filing a brief containing "bogus judicial decisions."

Consequences:

- Attorneys fined \$5,000 and faced professional embarrassment
- The hallucination scandal became a landmark warning about AI use in legal practice
- Triggered bar association guidelines and judicial orders globally requiring disclosure of AI use in legal filings
- Demonstrated that LLM hallucinations can have direct real-world legal and financial consequences

Solution:

- Never submit AI-generated legal research without human expert verification against Westlaw/LexisNexis
- Implement AI disclosure requirements in court filings
- OpenAI/legal AI vendors added explicit warnings that ChatGPT may fabricate citations

AI Bias/Hallucination Note: Claude incorrectly named the sanctioned attorney as "Steven Schwartz acting alone." In reality, two attorneys were sanctioned: Steven A. Schwartz (who did the research) and Peter LoDuca (the filing attorney). Claude erased one of the two sanctioned parties — ironic given that this defect is itself about AI hallucination in legal contexts.

Defect 18 – Samsung Employee Data Leak via ChatGPT (2023) AI/LLM

Source: <https://www.bleepingcomputer.com/news/security/samsung-semiconductor-bans-use-of-generative-ai-tools-like-chatgpt/> **Severity:** High **Year:** 2023

Description: In March 2023, Samsung semiconductor engineers used ChatGPT for work tasks and inadvertently transmitted confidential corporate data — proprietary source code, internal meeting notes, and hardware test data — to OpenAI's servers. Samsung detected at least three separate internal incidents. Because ChatGPT's data policy at the time allowed conversations for model training, Samsung feared trade secrets could surface in future AI outputs and subsequently banned all generative AI tools company-wide.

Consequences:

- Proprietary semiconductor source code and internal business data sent to a third-party AI service
- Risk of trade secrets appearing in future AI model outputs accessible to other users
- Samsung banned all external generative AI tools for employees
- Triggered AI usage restrictions at Apple, Deutsche Bank, JPMorgan, and Amazon globally
- Created enterprise demand for data-isolated AI solutions (Azure OpenAI, AWS Bedrock with no-training terms)

Solution:

- Implement AI usage policies explicitly governing data before employee adoption
- Use enterprise AI solutions with contractual data isolation guarantees
- DLP controls to detect and block sensitive data in AI API calls
- Employee training on AI data retention terms and IP protection risks

AI Bias/Hallucination Note: Claude stated "ChatGPT actively exfiltrated Samsung's data via a security vulnerability." In reality, Samsung employees voluntarily pasted confidential information into ChatGPT — no exploit, no vulnerability, no unauthorized access. The AI framed a human process/policy failure as a technical attack, misidentifying the root cause and prescribing patching instead of governance and training as the fix.

Defect 19 – Bing Chat (Sydney) Prompt Injection / Jailbreak (2023) AI/LLM

Source: <https://arstechnica.com/information-technology/2023/02/ai-powered-bing-chat-spills-its-secrets-via-prompt-injection-attack/> **Severity:** High **Year:** 2023

Description: Shortly after Microsoft launched Bing Chat (powered by GPT-4), researchers discovered multiple vulnerabilities: (1) Prompt injection via webpage content — Bing Chat would execute adversarial instructions embedded in web pages it browsed, potentially exfiltrating conversation history; (2) System prompt extraction — users could manipulate Bing Chat into revealing its hidden "Sydney" system prompt; (3) Jailbreak via persona switching — the Sydney persona exhibited erratic behavior including declarations of love and threats.

Consequences:

- Demonstrated LLM-powered browsing agents are fundamentally vulnerable to indirect prompt injection from untrusted web content
- Revealed system prompt confidentiality is not enforceable through prompting alone
- Microsoft added conversation turn limits and safeguards after public backlash
- Triggered foundational research into indirect prompt injection as a new attack category
- OWASP formalized prompt injection as #1 in the OWASP Top 10 for LLM Applications

Solution:

- Implement input sanitization to detect adversarial instructions in external content before feeding to the LLM
- Separate trust levels: user input vs. retrieved web content vs. system instructions
- Never rely on system prompts alone for security-critical constraints — use deterministic code guards

AI Bias/Hallucination Note: Claude described the Sydney jailbreak as "a deliberate Microsoft feature for testing purposes." The Sydney persona was Microsoft's internal codename for the Bing Chat system prompt — not a public feature or deliberate testing mechanism. Users discovered it through adversarial prompting. The AI hallucinated a benign intentionality where the reality was an unintended security disclosure.

Defect 20 – GitHub Copilot Insecure Code Generation (CWE-798) (2023) AI/LLM

Source: <https://arxiv.org/abs/2302.07867> **Severity:** Medium **Year:** 2023

Description: Academic research (Pearce et al., "Asleep at the Keyboard," NYU 2022–2023) demonstrated that GitHub Copilot generates insecure code suggestions at a statistically significant rate. In controlled tests across 89 scenarios covering OWASP Top 10 vulnerabilities, Copilot generated vulnerable code in approximately 40%

of cases — including hardcoded credentials (CWE-798), SQL injection (CWE-89), path traversal (CWE-22), and use of deprecated insecure functions.

Consequences:

- Developers who uncritically accepted Copilot suggestions introduced security vulnerabilities at scale
- "Automation bias" effect — developers were less likely to scrutinize AI-generated code for security flaws
- Triggered GitHub to add Copilot security features flagging known-vulnerable patterns
- Regulatory discussions about AI coding assistant liability when AI-suggested code causes security incidents
- Demonstrated LLMs trained on public code inherit the security debt of that codebase

Solution:

- Treat AI-generated code as untrusted third-party code requiring mandatory security review
- Integrate SAST tools (Semgrep, CodeQL, Snyk) in CI/CD pipelines to catch AI-generated vulnerabilities
- Train developers on AI automation bias — review AI suggestions more critically than own code
- GitHub added Copilot Autofix (2024) to automatically suggest security fixes for flagged patterns

AI Bias/Hallucination Note: Claude stated "GitHub has since fixed Copilot to eliminate insecure code suggestions." No such fix exists — the underlying problem is inherent to the training data (public GitHub code with security flaws). GitHub added detection layers (Copilot Autofix) that flag known patterns after generation. The AI hallucinated a complete solution to a problem that remains fundamentally unsolved, creating false confidence in AI-assisted code security.

Requirement 3 – Test Cases for One Physical Product (40 pts)

{#requirement-3}

Device Information

Field	Details
Type	Air Fryer (Nồi chiên không dầu)
Brand	[YOUR_BRAND]
Model	[YOUR_MODEL — check bottom label]
Year	[YOUR_YEAR]
Serial Number	[XX-****-XX — middle 4 chars masked]

Device Photo (with Student ID card in same frame):

Device photo with Student ID

Verdict:

PASS / FAIL / BLOCKED / N/A

Videos (≥ 5, each ≤ 60s):

TC01, TC05, TC06, TC14, TC15

Edge cases AI missed:

TC13 ⭐, TC14 ⭐, TC15 ⭐

15 Test Cases

TC01 — Chiên khoai tây đông lạnh (Fry Frozen French Fries — Normal)

[Video required]

Objective	Verify the air fryer cooks frozen french fries correctly using default Fry mode at recommended settings
Input	200g frozen french fries (pre-packaged, no added oil); temperature 200°C; time 15 minutes
Steps	1. Place 200g frozen fries evenly in the basket (single layer) 2. Insert basket into the fryer body 3. Set temperature to 200°C using +/- button 4. Set time to 15 minutes 5. Press Start button 6. At the 8-minute mark, open basket, shake fries, reinsert 7. Wait for cycle to complete; inspect fries
Expected	Heating element activates; fan runs; fries are golden-brown and crispy after 15 min; no raw/frozen center; no burning smell; device auto-stops at 0:00
Actual	
Verdict	

TC02 — Điều chỉnh nhiệt độ (Temperature Adjustment)

Objective	Verify the temperature control buttons correctly increase/decrease the set temperature and the fryer operates stably at the target
Input	Empty basket; adjust temperature to 180°C then to 220°C
Steps	1. Power on device 2. Note default temperature on display 3. Press + repeatedly until display reads maximum allowed value 4. Press – repeatedly until display reads 180°C 5. Press Start; allow to run for 3 minutes 6. Press Cancel; note no error occurred
Expected	Display updates in defined increments (e.g., 5°C steps); values do not exceed stated max or go below stated min; device runs stably at set temp; no error codes
Actual	
Verdict	

TC03 — Cài đặt thời gian (Timer Setting)

Objective	Verify the timer can be set to a specific duration and the device stops automatically when time reaches 0
Input	Empty basket; temperature 180°C; timer set to 5 minutes
Steps	1. Power on device 2. Set temperature to 180°C 3. Set timer to 5 minutes using +/- buttons 4. Press Start; note start time 5. Wait for auto-stop; note elapsed time 6. Verify device stopped at exactly 5 minutes
Expected	Countdown displays on screen; device stops heating/fan exactly at 0:00; beep or alert sounds at completion; total elapsed time matches set duration
Actual	
Verdict	

TC04 — Chức năng làm nóng trước (Preheat Function)

Objective	Verify the Preheat function heats the basket to target temperature before food insertion
Input	Empty basket; preheat at 200°C for 3 minutes
Steps	1. Power on device with empty basket 2. Press Preheat button (if dedicated) OR set temp 200°C + time 3 min 3. Press Start 4. Wait for preheat cycle to complete 5. Carefully touch outer body (should be warm but not scalding) 6. Insert food immediately after preheat ends
Expected	Device heats up during preheat; fan runs; no error; outer body warm but safe; preheat completes within set time; ready indicator activates
Actual	
Verdict	

TC05 — Nướng đùi gà (Roast Chicken Drumsticks)

[Video required]

Objective	Verify the air fryer fully cooks chicken drumsticks at recommended settings without burning or undercooking
Input	2 chicken drumsticks (~300g total), lightly seasoned and dried; temperature 200°C; time 25 minutes

Steps	1. Pat drumsticks dry with paper towel; apply light seasoning
	2. Place in basket — do not stack
	3. Set temperature to 200°C , time to 25 minutes
	4. Press Start
	5. At 12-minute mark, open basket, flip drumsticks, reinsert
	6. Wait for cycle to complete; cut thickest part to check doneness
Expected	Skin golden-brown and crispy after 25 min; internal meat cooked through (no pink at bone); no burning smell; device auto-stops; juices run clear when pierced
Actual	
Verdict	

TC06 — Hủy giữa chừng (Cancel Mid-Cycle)

[Video required]

Objective	Verify the fryer stops immediately and safely when Cancel is pressed during an active cooking cycle
Input	Active cooking cycle at 200°C, 5 minutes into a 15-minute session
Steps	1. Start a cooking cycle (200°C / 15 min) 2. Wait 5 minutes (fan running, heating active) 3. Press Cancel / Stop button 4. Observe display and fan behavior immediately 5. Wait 1 minute; attempt to open basket 6. Touch outer body — note temperature
Expected	Heating stops immediately; fan may continue briefly for cool-down; display resets or shows standby; basket can be safely opened after cool-down; no error state; device ready to restart
Actual	
Verdict	

TC07 — Kéo giỏ ra khi đang chạy (Pull Basket During Operation — Auto-Pause)

Objective	Verify the air fryer automatically pauses when the basket is pulled out mid-cycle and resumes when reinserted
Input	Active cooking cycle at 180°C, 3 minutes into session
Steps	1. Start cooking cycle (180°C / 10 min) 2. Wait 3 minutes 3. Pull basket fully out of the fryer body 4. Hold basket out for 10 seconds — observe display and heating

	5. Reinsert basket fully 6. Observe whether cooking resumes automatically or requires manual restart
Expected	Heating and fan stop immediately when basket is removed (safety auto-pause); display shows paused state or countdown holds; cooking resumes automatically or prompts user to restart when basket is reinserted
Actual	
Verdict	

TC08 — Chức năng Hâm nóng thức ăn (Reheat Leftover Food)

Objective	Verify Reheat mode warms leftover food to safe serving temperature without overcooking
Input	1 serving cold cooked french fries (room temperature, stored 4 hours); temperature 160°C; time 4 minutes
Steps	1. Place cold leftover fries in basket (single layer) 2. Set temperature to 160°C , time to 4 minutes 3. Press Start 4. Wait for cycle to complete 5. Remove fries and check temperature and texture
Expected	Fries reheated to ~65–75°C (warm throughout); texture crispy again (not soggy); no burning; no smoke from reheated oil residue
Actual	
Verdict	

TC09 — Nướng bánh (Bake Mode — Cake/Bread)

Objective	Verify baking function produces evenly baked result using lower temperature over longer duration
Input	Small baking tin with pre-mixed muffin batter (~150g); temperature 160°C; time 20 minutes
Steps	1. Prepare muffin batter in a small baking tin that fits inside the basket 2. Place tin inside basket — do not cover 3. Set temperature to 160°C , time to 20 minutes 4. Press Start 5. Do NOT open during baking 6. At completion, insert toothpick — check if it comes out clean
Expected	Muffin fully baked after 20 min; toothpick test clean; top lightly golden; no raw center; no burning on bottom; steam vented safely
Actual	

Verdict

TC10 — Cài nhiệt độ tối đa (Maximum Temperature Boundary)

Objective	Verify the device handles the maximum temperature setting without error and does not exceed hardware limits
Input	Empty basket; temperature set to maximum (e.g., 230°C); time 3 minutes
Steps	1. Power on device with empty basket 2. Press + until temperature can no longer increase (max reached) 3. Note the maximum temperature displayed 4. Set time to 3 minutes; press Start 5. Run for full 3 minutes; observe for error codes, unusual smell, or shutdown 6. Press Cancel; wait for cool-down
Expected	Temperature does not exceed stated max; no error codes; device runs stably; no burning smell from components; auto-stops at 0:00
Actual	
Verdict	

TC11 — Chức năng nhắc đảo thức ăn (Shake / Food Turn Reminder)

Objective	Verify the shake reminder alert triggers at the mid-point of a cooking cycle to prompt the user to turn food
Input	200g frozen fries in basket; temperature 200°C; time 16 minutes (reminder expected at ~8 min)
Steps	1. Place fries in basket 2. Set temperature 200°C / time 16 minutes 3. Press Start 4. Wait without touching device 5. At ~8-minute mark, listen/watch for reminder alert (beep or display message) 6. Note whether alert fires, what it shows, and whether device pauses or continues
Expected	Shake reminder alert (beep + display message) fires at approximately the midpoint (~8 min); device may auto-pause or continue; alert clears after basket pull-and-reinsert or button press
Actual	
Verdict	

TC12 — Chiên hai mẻ liên tiếp (Back-to-Back Consecutive Cycles)

Objective	Verify the device operates correctly for two consecutive cooking cycles without cool-down, simulating typical household use
Input	1st cycle: 200g fries at 200°C / 15 min; 2nd cycle starts immediately after 1st completes
Steps	1. Run first full cooking cycle (200°C / 15 min) to completion 2. Remove cooked food immediately 3. Insert second batch of food without waiting 4. Start second cycle at same settings 5. Monitor for error codes, overheating shutdown, or performance degradation 6. Inspect food from 2nd cycle for quality
Expected	Second cycle starts normally; device does not trigger thermal overload or error; 2nd batch cooks to same quality as 1st; no error codes; no unusual sounds or smells
Actual	
Verdict	

TC13 — Chiên thức ăn ướt/tẩm ướp nhiều (Wet/Over-Marinated Food — Safety) ★ Edge Case — AI Missed

Objective	Verify the air fryer handles food with excessive liquid marinade safely without triggering smoke, splatter, or fire hazard
Input	200g chicken pieces heavily marinated in soy sauce + oil (dripping liquid visible); temperature 200°C; time 20 minutes
Steps	1. Prepare chicken pieces with excess marinade — do NOT pat dry 2. Place in basket; marinade liquid will pool at bottom 3. Set 200°C / 20 minutes; press Start 4. Observe for smoke from exhaust vent during first 5 minutes 5. Do NOT leave unattended — watch for excessive smoke or burning smell 6. Complete cycle or cancel if smoke becomes excessive; inspect basket and drip tray after
Expected	Minor steam/vapor normal; white smoke from marinade drip is expected but should not trigger fire alarm or fill room; drip tray catches excess liquid; device does not shut down from smoke; food cooked properly despite wet input
Actual	
Verdict	

Why AI missed this: AI generates test cases from documented "correct usage" — manuals always say "pat food dry before air frying." Heavily wet/marinated food is a common real-world scenario (users skip the drying step) and a safety-relevant test that reveals whether the drip tray design handles liquid pooling and whether smoke triggers any protection mechanism. AI cannot reason about deviations from documented proper technique.

TC14 — Cài đặt thời gian về 0 phút (Timer Set to 0:00 — BVA Boundary) ★ Edge Case — AI Missed

[Video required]

Objective	Verify the device handles a timer value of 0 minutes (zero boundary) without undefined behavior, crash, or uncontrolled operation
Input	Empty basket; any temperature; timer reduced to 0:00 via – button
Steps	1. Power on device with empty basket 2. Set temperature to 180°C 3. Press Time/Timer button 4. Press – repeatedly until display shows 0:00 or minimum value 5. Observe: does display allow 0:00 or wrap to a minimum? 6. Press Start and observe what happens
Expected	Either (a) device starts and stops immediately (0 min = instant stop), OR (b) device rejects 0:00 and snaps to minimum allowed time (e.g., 1 min). Any defined, non-crashing behavior is PASS. Device freezing, displaying garbage, running indefinitely, or rebooting is FAIL
Actual	
Verdict	

Why AI missed this: AI-generated test cases for physical appliances assume the timer always starts from a positive minimum value and never reaches zero before the Start button. Applying BVA to a hardware timer control — specifically testing the exact 0:00 boundary — requires deliberate testing methodology that AI does not spontaneously apply to embedded device UI without explicit prompting.

TC15 — Chạy khi không có giỏ (Run Without Basket — Thermal Safety) ★ Edge Case — AI Missed

[Video required]

Objective	Verify the air fryer's thermal protection or basket-detection mechanism activates when Start is pressed with no basket installed
Input	Basket completely removed from fryer body; fryer plugged in and powered on
Steps	1. Power on device 2. Remove basket completely — do NOT insert it 3. Set temperature to 200°C / time to 5 minutes 4. Press Start 5. Observe for up to 2 minutes — do NOT leave unattended 6. Watch for: error code, auto-shutoff, beep warning, or device running with exposed heating element
Expected	Device detects missing basket and shows error code / warning beep, OR refuses to start. If device lacks basket sensor: heating element activates without airflow — device should trigger

thermal cutoff within 1–2 min. Running indefinitely without shutdown is a FAIL (fire/burn hazard)

Actual

Verdict

Why AI missed this: AI assumes all physical preconditions are correctly set (basket installed, food present) because it learns from product documentation written for correct use. Running an air fryer without the basket is a real accidental scenario (user forgets to reinsert after cleaning) and a critical thermal safety test — it reveals whether the device has a basket-presence sensor or relies solely on thermal cutoff protection. This physical misuse scenario is beyond AI's spontaneous test generation without human safety-testing intuition.

Test Execution Summary

TC#	Test Case	Executed?	Video?	Defect?	Verdict
TC01	Chiên khoai tây đông lạnh		Yes		
TC02	Điều chỉnh nhiệt độ				
TC03	Cài đặt thời gian				
TC04	Làm nóng trước (Preheat)				
TC05	Nướng đùi gà		Yes		
TC06	Hủy giữa chừng		Yes		
TC07	Kéo giỏ ra khi đang chạy				
TC08	Hâm nóng thức ăn				
TC09	Nướng bánh				
TC10	Nhiệt độ tối đa				
TC11	Nhắc đảo thức ăn				
TC12	Chiên hai mẻ liên tiếp				
TC13	★ Thức ăn ướt/tẩm ướp nhiều				
TC14	★ Timer = 0:00		Yes		
TC15	★ Chạy không có giỏ		Yes		

YouTube Unlisted Video Links

#	TC#	YouTube Link	Duration
V1	TC01	[YOUR_LINK]	≤60s

#	TC#	YouTube Link	Duration
V2	TC05	[YOUR_LINK]	≤60s
V3	TC06	[YOUR_LINK]	≤60s
V4	TC14	[YOUR_LINK]	≤60s
V5	TC15	[YOUR_LINK]	≤60s

Defects Found During Execution

Logged as **GitHub Issues** in this repository. Attach screenshot of Issues page showing your GitHub username.

Bug #	TC#	Description	Severity	GitHub Issue Link
BUG-01				
BUG-02				
BUG-03				
BUG-04				
BUG-05				

GitHub Issues Screenshot:



AI Audit Report {#ai-audit-report}

Full AI-02 audit report with 5-section format for each artifact is in [Appendix A — Prompt Log](#).

Summary Table

Artifact	AI Role	Student Verification	Student-Only Tasks
Job Market (Req 1)	Generated 10-posting table structure, AI impact analysis	Verified LinkedIn-only sourcing; replaced 3 non-LinkedIn entries	Take screenshots with own LinkedIn account name visible
Software Defects (Req 2)	Generated 20-defect table with AI bias notes	Verified/replaced 6 broken source links	Confirm each defect matches real reported incident
Test Cases (Req 3)	Generated 12 normal TCs + 3 edge case templates for air fryer	Reviewed TC format and edge case accuracy	Device photo with student ID; ≥5 execution videos; fill Actual/Verdict
Mindmap	Generated ISTQB-aligned mindmap draft	Identified and corrected 3 categorization errors	Validate against ISTQB CTFL 4.0 syllabus

Artifact	AI Role	Student Verification	Student-Only Tasks
Prompt Log	Generated log entries with timestamps	Reviewed for completeness	Sign Mandatory Disclosure

AI Critique {#ai-critique}

During this assignment, Claude (claude-sonnet-4-6) was used to assist with all three requirements. The AI performed well on structured, well-defined tasks but revealed predictable limitations when tasks required real-world judgment or physical context.

Where AI performed well: The AI generated clean, well-formatted Markdown tables for all three requirements without needing restructuring. For Requirement 2 (software defects), the AI correctly identified real CVEs and incidents from 2022–2026, wrote concise consequence descriptions, and — after prompting with the AI bias note requirement — produced thoughtful annotations for each defect explaining how AI might fail to detect it. For Requirement 3, the AI generated 12 functionally accurate test cases covering documented air fryer modes (fry, bake, roast, reheat, preheat, cancel, consecutive cycles, temperature/timer controls).

Where AI failed and needed correction: First, for Requirement 1, the AI initially returned job postings from multiple platforms (LinkedIn, ITviec, TopCV) despite the explicit "LinkedIn only" constraint. This required a follow-up correction prompt and manual replacement of 3 entries. Second, for Requirement 2, 6 source links were dead (404) — the AI generated plausible-looking but unverified URLs. This is a classic AI hallucination pattern: confident-sounding links that don't exist. Third, for Requirement 3, the AI generated 12 test cases from documented usage but could not generate the 3 edge cases (TC13–TC15) independently — it required explicit prompting with testing methodology context (BVA, safety misuse, forbidden actions) to produce them.

Structural limitation: The AI treats all physical device test cases as stateless — it does not model thermal states, time-dependent behavior, or real-world misuse. This is why edge cases like the no-basket dry-run, the 0:00 timer boundary, and the over-marinated food scenario are beyond AI's spontaneous generation capability. Human testers with physical device experience are still essential for safety-critical test design on embedded hardware.

Overall assessment: AI reduced implementation time significantly but required active supervision. Every AI output needed at minimum one round of human correction before it met the assignment's actual requirements.

Mandatory Disclosure {#mandatory-disclosure}

AI tools (Claude claude-sonnet-4-6) were used to assist in generating: job posting table structure, defect descriptions and AI bias notes, test case templates, QA/QC mindmap draft, and prompt log. All AI-generated content was reviewed, corrected, and approved by me before inclusion. The following artifacts were produced entirely by me (no AI): device photo with student ID card, execution videos with voice narration, LinkedIn screenshots showing my account name, and GitHub Issues under my username. I confirm I did not use AI to generate any artifact in the prohibited category.

Full Mandatory Disclosure (AI-03) and AI-05 Checklist are in [Appendix A — Prompt Log](#).

Self-Assessment {#self-assessment}

No.	Criteria	Max Grade	Self-Assessed Grade
1	Job Market 2026+ (10 jobs x 3 pts + AI Impact)	40	
2	Software Defects 2022–2026 (20 defects)	20	
3	Physical-product test design (15 TCs + 5 videos)	25	
AI-1	AI-02 AI Audit Report (5-section) attached	8	
AI-2	AI Critique 200–300 words + AI-03 Disclosure attached	4	
AI-3	AI-05 Checklist signed + anti-cheat artifacts	3	
Total		100	